

Command Injection Execution

Part 1: DVWA – Command Injection

In this task, I tested the **Command Injection** vulnerability in DVWA. The web application allows users to enter an IP address for a ping request, but the input is not properly sanitized. By injecting system commands along with the IP, it became possible to execute arbitrary OS commands on the server. I first tested basic injection using `127.0.0.1; whoami` and successfully retrieved the username **www-data**, proving command execution. I then tried multiple delimiters such as `&&`, `|`, and `&` to validate bypass methods. Additional commands like `ls` listed files on the server, confirming deeper system access. Finally, I used **Burp Suite Repeater** to send encoded payloads (e.g., `127.0.0.1%26%26id`) to simulate a real attack scenario and observed valid server responses, demonstrating that the vulnerability can be exploited both through the UI and intercepted HTTP requests.

Overall, these results show that the lack of input sanitization allows an attacker to run system commands directly on the host.





